Software Test Plan (STP) - Online Exam Portal

Project: Online Exam Portal
Version: 1.1
Authors: Chhavi Siddarth Wadhwa, Dhanya Prasad, Harsha K, Gagan
Date: 07-10-2026
Status: Final

1. Introduction

Purpose: This document defines the software test plan for the Online Exam Portal. It outlines the scope, test strategy, security validation, test environment, schedule, deliverables, responsibilities, risks, traceability and reporting.

Scope: Testing covers the web-based Online Exam Portal defined in SRS v1.2, including account and access management, question bank and exam management, exam publication and assignment, timed exam attempts, auto-save and resume, manual and automatic submission, evaluation, results and analytics, notifications, focus-loss logging and audit logging.

References: Online Exam Portal – Software Requirements Specification (SRS) v1.2; Software Architecture & Design Specification (SAD) v1.4; Requirements Traceability Matrix (RTM); ID_Cheat_Sheet; Test Plan template.

Definitions: SRS (Software Requirements Specification), STP (Software Test Plan), RTM (Requirements Traceability Matrix), FR (Functional Requirement), NFR (Non-Functional Requirement), SEC (Security Requirement), RBAC (Role-Based Access Control), MCQ (Multiple-Choice Question), MERN (MongoDB, Express.js, React, Node.js).

2. Test Items

- Account registration, email verification, login, logout and password reset.
- Administrator user and role management.
- Instructor question bank and exam creation/configuration.
- Exam publishing, Student assignment and notifications.
- Student assigned-exam dashboard and exam attempt.
- Question navigation, answer selection, flagging, server-clock timer, auto-save and resume.
- Manual and automatic submission and automatic evaluation.
- Student results, Instructor analytics and CSV export.
- Focus-loss recording and Administrator audit logs.
- REST APIs, persistence, email-triggering behaviour, security controls and supporting operational functions.

3. Features to be Tested

The following feature areas are mapped to the frozen SRS requirement IDs.

Feature Area	SRS IDs
Account & Access	FR-OE-001 to FR-OE-006; SEC-OE-001 to SEC-OE-006; SEC-OE-010
Question Bank & Exam Setup	FR-OE-007 to FR-OE-012; SEC-OE-008
Exam Assignment & Notifications	FR-OE-011, FR-OE-013, FR-OE-026; NFR-OE-007; SEC-OE-011
Exam Taking	FR-OE-014 to FR-OE-021; NFR-OE-005, NFR-OE-008, NFR-OE-009, NFR-OE-010; SEC-OE-007, SEC-OE-009
Submission & Evaluation	FR-OE-019, FR-OE-020, FR-OE-022; NFR-OE-003
Results, Analytics & Audit	FR-OE-023 to FR-OE-025, FR-OE-027; NFR-OE-006, NFR-OE-014; SEC-OE-011, SEC-OE-012
Performance, Availability & Capacity	NFR-OE-001, NFR-OE-002, NFR-OE-004, NFR-OE-011, NFR-OE-012, NFR-OE-013

4. Features Not to be Tested

- Descriptive or coding questions, because this release supports MCQs with a single correct option.
- Video/webcam proctoring.
- Native mobile applications.
- Payment functionality.
- Integration with external learning management systems.
- Internal implementation of the external SMTP provider beyond the Online Exam Portal's use of the service.

5. Test Approach / Strategy

Levels:

- Unit-level verification for applicable business logic, including evaluation and validation logic.
- Integration testing between the React client, Express/Node.js REST API, MongoDB and SMTP email service.
- System testing of end-to-end Student, Instructor and Administrator workflows.
- Acceptance-oriented testing against the SRS acceptance criteria.

Types:

- Functional testing for FR-OE-001 through FR-OE-027.
- Security testing for SEC-OE-001 through SEC-OE-012 using the SRS verification methods.
- Performance and load testing for NFR-OE-001, NFR-OE-002, NFR-OE-003, NFR-OE-004 and NFR-OE-011.
- Reliability and recovery testing for NFR-OE-005 and NFR-OE-006.
- Usability, accessibility and compatibility checks for NFR-OE-007, NFR-OE-008 and NFR-OE-009.
- Timing-accuracy testing for NFR-OE-010.
- Maintainability and deployment verification for NFR-OE-012 and NFR-OE-013.
- Data-retention verification for NFR-OE-014.
- Regression testing after defect fixes.

Entry Criteria: A testable integrated build is available; the required environment, HTTPS configuration, database and test accounts are available; the SRS/RTM baseline is frozen; required test data is prepared; and the supported browser environment is available.

Exit Criteria: 100% of planned test cases are executed; critical/blocking defects affecting required functionality are resolved or formally accepted; required security validations are completed; and SRS-to-test-case traceability is complete for the requirements covered by this plan.

5.1 Security Validation

Security ID	Security Area	Verification Method	Validation
SEC-OE-001	Password storage	Code review + DB inspection	Verify passwords are stored only as salted bcrypt/Argon2 hashes and are never stored or logged in plaintext.
SEC-OE-002	Password policy	Test	Verify passwords require at least 8 characters with upper-case, lower-case and a digit.
SEC-OE-003	Login lockout	Test	Verify the account is locked for 15 minutes after 5 consecutive failed login attempts.
SEC-OE-004	Server-side RBAC	Penetration / API test	Attempt role-inappropriate requests and verify HTTP 403.
SEC-OE-005	HTTPS/TLS	Scan	Verify HTTPS uses TLS 1.2 or higher and plain HTTP is rejected.
SEC-OE-006	Session security	Test	Verify 30-minute inactivity expiry and HttpOnly/Secure session-token attributes.
SEC-OE-007	Answer confidentiality	API response inspection	Verify correct answers are not sent to the client before the attempt is submitted and results are released.
SEC-OE-008	Input security	Security scan + test	Verify validation/sanitisation and protection against NoSQL/query injection, XSS and CSRF.
SEC-OE-009	Submission authorization	API test	Verify only the authenticated attempt owner can submit and submissions after the attempt end time plus 5-second grace period are rejected.

Security ID	Security Area	Verification Method	Validation
SEC-OE-010	Rate limiting	Test	Verify login/password-reset requests are limited to 10 per minute per IP and excess requests receive HTTP 429.
SEC-OE-011	Audit logging	Inspection	Verify required security-relevant events contain user ID, timestamp and IP and are retained for at least 12 months.
SEC-OE-012	Data at rest	Inspection	Verify personal data (email, name) and backups are encrypted at rest.

6. Test Environment

Hardware: Development/test machines and a test deployment capable of supporting the required concurrency tests.

Software: MERN application — React client, Node.js/Express REST API and MongoDB database; SMTP test service; HTTPS-enabled deployment.

Client: Latest two major versions of Google Chrome, Mozilla Firefox and Microsoft Edge; screen widths from 360 px upwards.

Tools: Browser/developer tools, Postman or equivalent REST API testing tool, JMeter or equivalent load-testing tool, MongoDB Compass or equivalent database inspection tool, and Git for version-controlled test artefacts.

Test Data: Student, Instructor and Administrator accounts; valid/invalid credentials; verification/reset links; MCQs with 2–6 options; exams with different durations, windows, marks, shuffle and negative-marking settings; assigned/unassigned Students; interrupted attempts; submissions and known-result datasets.

Environment Requirements: Reachable MERN application, MongoDB test database, accessible SMTP test service, HTTPS/TLS 1.2+ and role-based test accounts.

7. Test Schedule

Milestone	Planned Date / Time
Test case design and SRS/RTM traceability	04-Oct-2026
API/design alignment and integration	05-Oct-2026
Final regression and document freeze	06-Oct-2026 by 21:00
Submission	07-Oct-2026

8. Test Deliverables

- Software Test Plan (this document).
- Detailed test cases TC-OE-001 through TC-OE-010.
- Requirements Traceability Matrix entries for the test-case column.
- Security validation evidence for SEC-OE-001 through SEC-OE-012.
- Test data and test execution evidence, as applicable.
- Defect reports for failed tests.
- Final test execution/status summary.

9. Roles and Responsibilities

Role	Name	Responsibility
Test Plan & Test Cases	Dhanya Prasad	Prepare the STP, detailed test cases, security validation and SRS/RTM test traceability.
Requirements / SRS	Chhavi Siddarth Wadhwa	Maintain the SRS baseline and clarify requirement intent.
Architecture	Harsha K	Align architecture, component responsibilities and security architecture with requirements and testing needs.
Design	Gagan	Align API design and sequence diagrams with testable system behaviours and provide implementation details for API-related

Role	Name	Responsibility
		tests.

10. Risks and Mitigation

Risk	Mitigation
Delay in stable integrated build	Prepare requirement-based tests first and perform API/design alignment before execution.
API/design changes after test-case creation	Keep tests behaviour-based and update endpoint references only after the final API design is agreed.
Test environment or SMTP service unavailable	Use a controlled test environment and test email accounts; record blocked tests separately.
Load environment cannot reproduce 500 concurrent users	Document the achieved load and environment limits; do not claim compliance unless the stated NFR load is tested.
Security evidence unavailable before freeze	Plan database/configuration inspection, API tests and scans early enough to capture evidence before document freeze.

11. Assumptions & Dependencies

- The SRS v1.2 requirement IDs remain frozen during execution.
- The final application follows the MERN stack and the interfaces documented in the SAD.
- Student, Instructor and Administrator test accounts are available.
- A test SMTP service is available for verification, password reset and notification tests.
- Required exam and question test data can be created before execution.
- The final API design supports the behaviours represented by the test cases.
- Performance and availability claims are made only from measurements performed under the stated SRS NFR conditions.

12. Suspension & Resumption Criteria

Suspend testing if:

- The integrated environment is unavailable and blocks a significant portion of planned tests.
- A blocking defect prevents authentication, exam attempt or submission workflows.
- Required test data, database access, HTTPS or SMTP service is unavailable.
- The build changes materially so previously executed results are no longer valid.

Resume testing if:

- Blocking defects are resolved or an agreed workaround exists.
- The environment and required dependencies are restored.
- A stable build is available and impacted tests are identified for re-execution.

13. Test Case Management & Traceability

The RTM maps each SRS requirement to one or more test cases. The planned baseline contains ten test cases. API references below are taken from the SAD v1.4 API design; where an API is not the primary test surface, the test is performed through the UI, database, configuration, deployment or supporting evidence.

TC ID	Test Case	Requirement IDs	SAD/API References
TC-OE-001	Account Registration, Authentication, Logout & Credential Security	FR-OE-001, FR-OE-002, FR-OE-003, FR-OE-004; SEC-OE-001, SEC-OE-002, SEC-OE-005, SEC-OE-006	API-01, API-02, API-03, API-04; SD-01
TC-OE-002	Password Reset, Account Lockout & Rate Limiting	FR-OE-005; SEC-OE-003, SEC-OE-010	API-03, API-05, API-06; SD-01
TC-OE-003	Role-Based Access Control &	FR-OE-006, FR-OE-027; SEC-OE-004, SEC-OE-011	API-07, API-20

TC ID	Test Case	Requirement IDs	SAD/API References
	Audit Logging		
TC-OE-004	Question Bank & Exam Configuration Security	FR-OE-007, FR-OE-008, FR-OE-009, FR-OE-010, FR-OE-012; SEC-OE-008	API-08, API-09
TC-OE-005	Exam Publishing, Assignment, Dashboard & Notifications	FR-OE-011, FR-OE-013, FR-OE-026; NFR-OE-007, SEC-OE-011	API-10, API-11, API-19
TC-OE-006	Exam Attempt, Timer, Focus Loss & Submission Authorization	FR-OE-014, FR-OE-015, FR-OE-016, FR-OE-019, FR-OE-020, FR-OE-021; NFR-OE-008, NFR-OE-009, NFR-OE-010; SEC-OE-007, SEC-OE-009	API-12, API-13, API-14, API-15; SD-02, SD-03
TC-OE-007	Answer Auto-Save & Interrupted Attempt Recovery	FR-OE-017, FR-OE-018; NFR-OE-002, NFR-OE-005	API-13; SD-02
TC-OE-008	Manual/Automatic Submission & Automatic Evaluation	FR-OE-019, FR-OE-020, FR-OE-022; NFR-OE-003	API-15; SD-03
TC-OE-009	Results, Analytics, CSV Export, Audit & Data Protection	FR-OE-023, FR-OE-024, FR-OE-025, FR-OE-027; NFR-OE-006, NFR-OE-012, NFR-OE-014; SEC-OE-011, SEC-OE-012	API-07, API-16, API-17, API-18, API-20; M-08
TC-OE-010	Performance & Availability Under Load	NFR-OE-001, NFR-OE-002, NFR-OE-003, NFR-OE-004, NFR-OE-011, NFR-OE-012, NFR-OE-013	API-21; M-01 to M-05; deployment evidence

Requirement-to-test-case traceability summary:

Requirement(s)	Test Case(s)
FR-OE-001 to FR-OE-004	TC-OE-001
FR-OE-005	TC-OE-002
FR-OE-006	TC-OE-003
FR-OE-007 to FR-OE-012	TC-OE-004
FR-OE-011, FR-OE-013, FR-OE-026	TC-OE-005
FR-OE-014 to FR-OE-021	TC-OE-006; TC-OE-007
FR-OE-019, FR-OE-020, FR-OE-022	TC-OE-008
FR-OE-023 to FR-OE-025, FR-OE-027	TC-OE-009
NFR-OE-001	TC-OE-010
NFR-OE-002	TC-OE-007; TC-OE-010
NFR-OE-003	TC-OE-008; TC-OE-010
NFR-OE-004	TC-OE-010
NFR-OE-005	TC-OE-007
NFR-OE-006	TC-OE-009
NFR-OE-007	TC-OE-005
NFR-OE-008, NFR-OE-009, NFR-OE-010	TC-OE-006
NFR-OE-011, NFR-OE-012, NFR-OE-013	TC-OE-010
NFR-OE-014	TC-OE-009
SEC-OE-001, SEC-OE-002, SEC-OE-005, SEC-OE-006	TC-OE-001
SEC-OE-003, SEC-OE-010	TC-OE-002
SEC-OE-004, SEC-OE-011	TC-OE-003; TC-OE-009
SEC-OE-008	TC-OE-004
SEC-OE-007, SEC-OE-009	TC-OE-006
SEC-OE-012	TC-OE-009

13.1 Detailed Test Cases

The following detailed test cases provide the planned execution steps and expected results for TC-OE-001 through TC-OE-010. They form the detailed test-case baseline referenced in Section 8.

TC ID	Test Case	Steps	Expected Results
TC-OE-001	**Account Registration, Authentication, Logout & Credential Security**	1. Register a Student with a valid unique email and compliant password. 2. Open the verification email and use the link within 24 hours. 3. Log in with valid credentials and inspect the session cookie. 4. Repeat login with an invalid password and inspect stored/logged credential data. 5. Click Logout and attempt to use the previous session.	1. Account is created; duplicate email is rejected; password is not stored in plaintext. 2. Account becomes verified and the link cannot be reused after expiry. 3. Login succeeds and an HttpOnly/Secure/SameSite session cookie is issued over HTTPS. 4. Generic authentication failure is returned; plaintext passwords/tokens are not stored or logged. 5. Session is invalidated immediately and protected requests require a new authenticated session.
TC-OE-002	**Password Reset, Account Lockout & Rate Limiting**	1. Request a password reset for a verified account.	1. A one-time reset link is sent and expires after 30 minutes.

TC ID	Test Case	Steps	Expected Results
		2. Use the one-time reset link within 30 minutes and set a compliant password. 3. Enter an incorrect password five consecutive times. 4. Attempt another login while the lockout is active. 5. Send more than 10 login/password-reset requests from the same IP within one minute.	2. Password is changed successfully and the reset link cannot be reused. 3. Account is locked for 15 minutes after the fifth consecutive failure. 4. Login is blocked with the defined lockout response and retry information. 5. Excess requests receive HTTP 429 and normal requests resume after the rate limit window.
TC-OE-003	**Role-Based Access Control & Audit Logging**	1. Log in separately as Student, Instructor and Administrator. 2. Attempt an Instructor-only and Administrator-only API action using a Student account. 3. As Administrator, create/edit/deactivate a user and change a role. 4. Open the Administrator audit-log view and filter by user/date.	1. Each role receives only its permitted features. 2. Out-of-role requests are rejected server-side with HTTP 403. 3. User-management changes succeed only for the Administrator and are recorded. 4. Required audit events show user ID, timestamp and IP and can be filtered as specified.
TC-OE-004	**Question Bank & Exam Configuration Security**	1. Create MCQs with 2, 6, 1 and 7 options and vary the number of correct options. 2. Create an exam with duration, start/end time, pass mark and selected questions. 3. Enable/disable question and option shuffling and configure negative marking. 4. Start the exam as a Student, then try to edit its questions, marks or duration. 5. Submit malicious/invalid input through question and exam APIs.	1. Only 2–6 options with exactly one correct option are accepted. 2. Exam is created with the supplied valid configuration and selected question set. 3. Configured shuffle and negative-marking behaviour is applied. 4. Editing protected exam configuration is rejected after the first Student starts. 5. Invalid or malicious input is rejected/sanitised; NoSQL injection and XSS/CSRF protections remain effective.
TC-OE-005	**Exam Publishing, Assignment, Dashboard & Notifications**	1. As Instructor, publish an exam and assign it to selected Students. 2. Log in as an assigned Student and open the exam dashboard. 3. Log in as an unassigned Student and check the dashboard. 4. Trigger assignment and result notifications and record delivery time.	1. Exam is published only with the configured assignment. 2. Assigned Student sees title, duration, time window and status and can locate the exam within 3 clicks. 3. Unassigned Student cannot access the exam as an assigned exam. 4. In-app and email notifications are generated within 2 minutes of the applicable event.
TC-OE-006	**Exam Attempt, Timer, Focus Loss & Submission Authorization**	1. Try to start an assigned exam before its start time, then start it within the exam window. 2. Change answers, navigate between questions and flag a question. 3. Compare the displayed timer with the server time and attempt to start the same exam again. 4. Switch tabs/lose focus and inspect the recorded event. 5. Attempt submission as another Student and after the end time plus 5 seconds.	1. Start is rejected outside the exam window and succeeds once within the valid window. 2. Answers, navigation and flags are retained as required. 3. Timer follows the server clock, the same exam cannot be started twice, and resume uses the original end time. 4. Focus loss/tab switch is recorded with the required timestamp and is visible to the Instructor. 5. Non-owner submission is rejected with HTTP 403; submission after the grace period is rejected without changing the attempt.
TC-OE-007	**Answer Auto-Save & Interrupted Attempt Recovery**	1. Change an answer and verify an autosave is triggered; continue making changes for more than 30 seconds. 2. Interrupt network connectivity and make additional answer changes. 3. Restore connectivity and allow retry/save processing to complete. 4. Close the browser during an IN_PROGRESS attempt and log in again before the original end time.	1. Answer changes are saved and periodic autosave occurs at least every 30 seconds; p95 latency meets NFR-OE-002 under the stated load. 2. Unsaved changes are retained locally while offline and are not silently lost. 3. Queued changes are retried and saved; server data reflects the latest valid sequence. 4. The attempt resumes with saved answers and the original end time; no more than 30 seconds of answers are lost after a server failure.
TC-OE-008	**Manual/Automatic Submission & Automatic Evaluation**	1. Answer some questions and choose manual Submit. 2. Verify the unanswered count and cancel once, then confirm submission. 3. Run an attempt to timer zero and verify automatic submission; also verify server-side auto-submit for an interrupted browser session. 4. Use a known answer set with positive and negative marks and compare the calculated score.	1. Submit confirmation shows the correct unanswered count and allows the Student to go back. 2. Confirmed manual submission changes the attempt to SUBMITTED and cannot be duplicated. 3. Timer-zero and server auto-submit finalize the attempt using the saved answers. 4. Evaluation uses the stored correct options, marks and negative-marking rule; score/pass-fail are returned within 5 seconds for the stated

TC ID	Test Case	Steps	Expected Results
			load.
TC-OE-009	**Results, Analytics, CSV Export, Audit & Data Protection**	1. Submit an attempt and open the Student result page immediately. 2. Before the exam end time, attempt question-wise review; repeat after the exam end time when review is enabled. 3. As Instructor, open attempts/analytics and export results to CSV. 4. As Administrator, inspect the relevant audit entries and retention controls. 5. Inspect stored personal data and backups using the approved test environment.	1. Score and pass/fail are displayed immediately after submission. 2. Correct-answer review is unavailable before exam end and becomes available after exam end only when enabled by the Instructor. 3. Attempts, scores and statistics are shown correctly and CSV export contains the expected results. 4. Required result/audit events are recorded and retained for at least 12 months. 5. Personal data and backups are encrypted at rest; backups meet the defined retention requirement and attempts/results are retained for at least one year.
TC-OE-010	**Performance & Availability Under Load**	1. Run page/API load tests at 500 concurrent users and measure response-time percentiles. 2. Run 500-concurrent autosave traffic and measure p95 save latency. 3. Run up to 500 simultaneous submissions and measure evaluation latency. 4. Exercise the health endpoint and observe availability during the scheduled test window. 5. Verify representative data volumes and inspect business-logic unit-test coverage and deployment setup evidence.	1. At least 95% of page requests complete within 2 seconds. 2. At least 95% of autosaves complete within 1 second. 3. Evaluation and score are completed within 5 seconds for the stated load. 4. Availability evidence supports the 99.5% target during the measured exam window. 5. Capacity supports at least 10,000 questions, 1,000 users and 200 exams without violating the response-time target; business-logic coverage is at least 70% and the documented Linux/container deployment setup is achievable within 60 minutes.

14. Test Metrics & Reporting

- Test execution percentage = executed / planned × 100.
- Pass percentage = passed / executed × 100.
- Fail percentage = failed / executed × 100.
- Requirement coverage = requirements mapped to at least one planned test case / requirements in the test baseline × 100.
- Security validation coverage = security requirements with planned validation / 12 × 100.
- Defect count by severity and defect aging.
- Performance measurements: response-time percentiles, auto-save latency, evaluation latency and observed availability where applicable.

Reports: Daily execution status during execution; defect reports; security validation evidence; and final test summary/status report.

15. Approvals

Role	Name	Signature / Date
Test Plan & Test Cases	Dhanya Prasad	
Requirements / SRS	Chhavi Siddarth Wadhwa	
Architecture	Harsha K	
Design	Gagan	
Instructor / Reviewer		